

On Security Vulnerabilities in Transportation IoT Devices

Jason Yih
University of Maryland
College Park, MD
jyih@umd.edu

Katerina Goseva-Popstojanova
West Virginia University
Morgantown, WV
Katerina.Goseva@mail.wvu.edu

Michel Cukier
University of Maryland
College Park, MD
mcukier@umd.edu

Abstract—This paper presents an empirical investigation of security vulnerabilities in four categories of transportation IoT devices: Electric Vehicle (EV) Chargers, EVs, non-EVs, and Other Traffic Devices. The results are based on data extracted from the Common Vulnerabilities and Exposures (CVEs) reported in the National Vulnerability Database (NVD). We analyzed 159 CVEs and explored the CWE (Common Weakness Enumeration) and CVSS (Common Vulnerability Scoring System) information associated with them. Our results showed that the security vulnerabilities were distributed unevenly across the 23 vulnerability classes, with the top six most common classes accounting for 74% to 89% of all vulnerabilities in each category of IoT devices. EV Chargers had the highest mean and median CVSS severity score, followed by Other Traffic Devices and EVs. Non-EVs had the lowest CVSS, which were statistically significantly different than the other categories of transportation IoT devices. The paper also presents the lessons learned and the practical implications of our empirical findings.

Index Terms—Security vulnerabilities, severity, transportation IoT devices, empirical study.

I. INTRODUCTION

Transportation systems and devices are increasingly becoming connected to the Internet. Cars, traffic devices, and transportation systems have become integrated into the Internet of Things (IoT). As a result, they are parts of the critical infrastructure and are common targets of cyberattacks. Thus, the transportation industry was the eighth most common target of cyberattacks in 2023, accounting for 4.3% of the total cyberattacks [1]. The increasing use of connected technologies leads to more vulnerabilities that can be exploited by malicious adversaries, and thus a higher risk.

To better understand the risks associated with IoT transportation devices, this paper presents an empirical study on security vulnerabilities in these devices. Specifically, we focus on studying security vulnerabilities that affect electric vehicle (EV) chargers, EVs, non-EVs, and other traffic devices that are connected to the Internet. We collect the CVEs related to transportation IoT devices from the NIST's NVD [2] and from these CVEs extract the information about their specific individual vulnerabilities (i.e., CWEs), severity (i.e., CVSS scores and severity levels), and affected components. Then, following the approach introduced in [3], we group the individual CWEs into 23 vulnerability classes of the CWE-888 Software Fault Patterns view [4] with the goal of categorizing the security vulnerabilities. Furthermore, we analyze the associated CVSS

scores, which integrate the exploitability and impact aspects of each security vulnerability.

This paper addresses the following research questions from the perspective of developers and manufacturers of transportation IoT devices:

- RQ1: What are the dominant vulnerability classes in different categories of transportation IoT devices?
- RQ2: What are the CVSS severity scores of different categories of transportation IoT devices?

The main contributions of this paper are:

- We extract information on security vulnerabilities associated with transportation IoT devices from NVD and conduct empirical analysis that allowed us to identify:
 - The dominant vulnerability classes for four different categories of transportation IoT devices, and the most vulnerable components in each category.
 - Typical CVSS severity scores for each category of IoT devices, and components that have vulnerabilities with high and critical severity levels.
- We compile the lessons learned and implications of our findings, and provide insights that can be used both by researchers and practitioners to improve the security of transportation IoT devices.

A few previous empirical studies focused on security vulnerabilities in vehicles [5]–[7], were published almost six years ago, and did not consider the type of vehicles (i.e., EVs and Non-EVs). In this study, we separately consider the EVs and Non-EVs categories of vehicles and present a more comprehensive analysis than prior works [5]–[7]. Furthermore, we explore the security vulnerabilities of two additional categories of transportation IoT devices – EV chargers and Other Traffic Devices¹ – for which, to the best of our knowledge, no previous empirical studies exist. Like [3], which was focused on mission-critical software, we use CWE-888 to group the vulnerabilities into 23 high-level vulnerability classes and subsequently to identify several dominant classes of vulnerabilities for each category of IoT devices. While [5]–[7] did discuss the CVSS scores of the vulnerabilities found in connected vehicles, we analyze the CVSS scores for the four

¹For Other Traffic Devices, we focused on devices that directly affect traffic and cars. Specifically, we considered the traffic controllers and their software, dash cameras, and automotive microcontrollers.

categories of IoT devices and compare them, including testing whether the differences are statistically significant. Finally, based on a comprehensive synthesis of our findings, we compile a list of lessons learned that identify overall patterns of security vulnerabilities in transportation IoT devices and provide actionable recommendations that can be useful for researchers and practitioners.

The paper is organized as follows. Section II presents the related works. The methodology used to conduct this study is explained in Section III. Section IV presents the results related to vulnerability classes, while Section V discusses the results of the analysis of CVSS scores. The lessons learned and the practical implications of our findings are summarized in Section VII. The threats to validity are discussed in Section VI and the paper is concluded in Section VIII.

II. RELATED WORK

Prior empirical studies of software vulnerabilities were focused on different domains, such as Android apps [8], [9], operating systems [10], mission critical software [3], embedded devices used in power grids [11], machine learning libraries [12], and Python packages [13].

Related non-empirical works focused on the transportation domain included the work by Acharya et al. [14] which described the vulnerabilities that emerge from EVs, EV chargers, and the power grid. Ronanki and Karneddi [15] focused on EV chargers, and found that off-board and wireless chargers were the most vulnerable to cyberattacks, while on-board chargers were less vulnerable. Bhusal et al. [16] detailed the possible cyber-physical risks of smart charging management systems, such as data injection, man-in-the-middle, and DoS attacks. Pourmirza and Walker [17] gave recommendations on how to mitigate attacks against EV charging infrastructure. Nasr et al. [18] conducted a systemic analysis of EV Charging Station Management Systems and discussed the implications. Muhammad et al. [19] discussed the security of mobile applications that manage EV usage. Shirvani et al. [20] developed a framework for assessing security during EV development and security profiling for EVs. Johnson et al. [21] developed threat models and analyzed the risks of cyberattacks on EV charging infrastructure, as well as proposed an approach for securing this infrastructure. Feng et al. [22] provided an analysis framework for traffic signal control systems and found that the most plausible attack on these systems was data spoofing. Sharma and Gillanders [23] studied connected autonomous vehicles and their security challenges.

Only a few empirical studies on vulnerabilities in the transportation domain exist [5]–[7], and all were focused on connected vehicles. Xiong et al. [5] conducted an empirical study on vehicle vulnerabilities, investigating EVs and Non-EVs along with their connected components. Using the NVD’s “Keyword Search” they found a total of 44 CVEs. In these, there were 21 unique CWEs related to vehicles. They found that the most common CWE was Protection Mechanism Failure, implying that protection mechanisms often have problems or may be missing. In terms of CVSS metrics, they found

that over half of the vulnerabilities were categorized as High severity. They also found that 52% of the vulnerabilities were able to be exploited remotely through the network. Kaya [6] studied connected automobiles, focusing on components of both EVs and Non-EVs and vulnerabilities affecting them (i.e., on Controller Area Network (CAN), Infotainment systems, and telematics control unit (TCU)). Kaya found 211 vulnerabilities related to these components through NVD. The most common CWE in these vulnerabilities was Protection Mechanism Failure with seven vulnerabilities. Kaya analyzed the component distribution and reported that 47% of them were related to the infotainment system and 39% were related to the TCU. Kaya found that the majority of vulnerabilities in these components and vehicles were exploitable through the network, and had a high impact on the systems they affect. Gülsever [7] studied vulnerabilities in connected cars (EVs and Non-EVs) using NVD, along with security incidents from Upstream Security. He found that 67.5% of these vulnerabilities could be exploited remotely. The components that had the most vulnerabilities associated with them were the infotainment system, mobile app, CAN, and TCU.

III. OUR METHODOLOGY

In this section, we describe the methodology used in this paper. First, we identified different types of devices that belong to the four categories of transportation IoT devices and collected the CVEs reported about them in NVD [2]. Then, we extracted the CVEs’ characteristics, including the corresponding CWEs and CVSS information. Motivated by a previous study [3], we grouped the individual CWEs into primary clusters of the CWE-888 view [4] which allowed us to build a ‘big picture’ of security vulnerabilities in transportation IoT devices. We also analyzed the CVSS scores and severity levels for each category of IoT devices.

Note that the empirical work presented in this paper follows the case study (i.e., observational) approach based on publicly available data in NVD that are entered and validated by experts and are widely used by researchers and practitioners. Using an experimental approach (e.g., conducting penetration testing) or a survey (e.g., collecting expert opinions) are complementary empirical approaches that are out of the scope of this paper.

A. CVE collection from NVD

CVEs are publicly known security vulnerabilities that are reported in NVD [2] and attributed to specific software applications or libraries. In order to collect CVEs related to transportation IoT devices from NVD, we first had to identify the companies and corresponding brands and names of such devices. For EV charging stations, we identified the brands and names using the list of manufacturers provided by the Electric Drive Transportation Association [24]. For EVs, we collected the information from the IRS list of EV manufacturers eligible for tax credit [25]. Note that peripheral devices, such as wireless OBD-II dongles [26], were not included in this study. For Non-EVs, we identified the major vehicle manufacturers from the US News List of “All the Car Brands Available

in America” [27]. For Other Traffic Devices category, we researched types of devices that directly affect traffic and cars, and then decided to focus on traffic controllers and their software, dash cameras, and automotive microcontrollers. For each of these, we used Google search to obtain a list of companies that produce that type of device and then ran queries to confirm the information. Note that CVE entries for Qualcomm products reported in NVD listed many chips. Since we were not able to confirm if these chips were related to automotive microcontrollers, we took a conservative approach and excluded all Qualcomm’s CVEs from the analysis. Note that studying intelligent road infrastructure devices, such as traffic signs, bus stops, and parking systems, is out of the scope of this paper.

We collected the data from NVD from January 2024 until April 2024. In total, we collected 159 CVEs, broken down per IoT device categories as shown in Table I. Figure 1 depicts how these CVEs were distributed over the years. (No vulnerabilities were reported for 2024 due to a backlog of vulnerabilities in NVD early that year.) Table II presents the names of the manufacturers associated with the 159 CVEs. (Open Charge Point Protocol was specifically referenced and is used by multiple manufacturers.)

TABLE I
CVEs AND CORRESPONDING CWEs PER IoT DEVICE CATEGORY

Type	EV Chargers	EVs	Non-EVs	Other Traffic Devices	Total
CVEs	49	46	28	36	159
CWEs	54	38	24	33	149

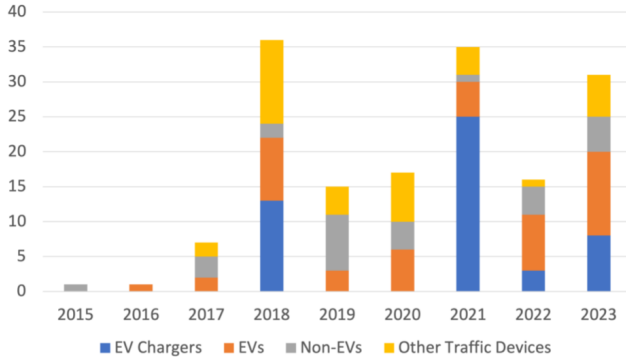


Fig. 1. Numbers of CVEs reported by year

B. CWE and CVSS data extraction

Each CVE is typically attributed to one or more CWEs. However, some CVEs did not have enough information to be associated with CWE in the NVD or were not in NVD’s CWE mapping [28]. These CVEs are listed as NVD-CWE-noinfo and NVD-CWE-Other, respectively. Out of the total 159 CVEs, 22 were NVD-CWE-noinfo and two were NVD-CWE-Other. These 24 CVEs were included in our CVE analysis but did not contribute to our CWE analysis. In total, 149 CWEs were associated with the 159 CVEs, broken down by IoT device categories as shown in Table I. These 149 CWEs were actually attributed to only 57 unique CWEs.

For each of the 159 CVEs, we also extracted the CVSS information. CVSS scores range from 0 to 10 and are calculated based on the vulnerability’s exploitability and impact [29]. CVSS severity is based on the scores. Thus, 0 score indicates None severity level. Severity levels of Low, Medium, High, and Critical correspond to score ranges from 0.1 to 3.9, from 4.0 to 6.9, from 7.0 to 8.9, and from 9.0 to 10, respectively.

Lastly, for each CVE, we manually extracted information about the vulnerable components from the CVEs’ descriptions.

C. Mapping individual CWEs to the CWE-888 view

CWE is a community-developed taxonomy of common weaknesses which is maintained by MITRE [30]. Currently, there are 940 weaknesses organized in a hierarchical structure. The top-level CWEs represent broad vulnerability categories; the vulnerabilities become more specific further down into the hierarchy. Since the CWE hierarchical structure is complex, several CWE views (e.g., CWE-888 [4], CWE-699 [31]) have been developed. We chose the CWE-888 Software Fault Patterns view to categorize the identified CWEs related to transportation IoT devices for the following reasons: (i) it was used in [3], which allows consistency and direct comparison of results and (ii) it is focused on fault categorization. Thus, CWE-888 is more technical, and captures wider range of potential weaknesses than other views such as the CWE-699 Software Development view [31]. The CWE-888 view contains 614 CWEs while the CWE-699 view has 399 CWEs.

In this work, we use the most recent version of CWE-888, which was last updated on June 29, 2023. We focus only on the 23 primary clusters of CWE-888 and refer to them as primary vulnerability classes. If the CWE identified as described in Section III-B is a part of the CWE-888 view, we mapped it to the corresponding primary class. If not, we looked at its parent CWEs and mapped them to the CWE-888 view. For example, CWE-798 Use of Hard-coded Credentials is not in the CWE-888 view. Therefore, we identified the CWE-798’s parents CWE-344 and CWE-671. These CWEs are in the CWE-888 view under the Predictability primary class and Other primary class respectively, making CWE-798 count towards both primary classes. There were only 10 CVEs (i.e., around 6%) with CWEs for which two parents were included in the CWE counts. This approach allowed us to build a more complete picture of different types of vulnerabilities while limiting over-counting the CWEs. On the other end, there were six CVEs that had two specific CWEs listed. For five of these, both CWEs were mapped to the same CWE-888 primary class, and only one was mapped to two different primary classes. Note that the CWE-888 Other primary class contains vulnerabilities related to Architecture, Compiler, Design, or Implementation.

IV. RQ1: ANALYSIS OF VULNERABILITY CLASSES IN TRANSPORTATION IoT DEVICES

To answer RQ1, we refer to Table III, which shows the numbers and percentages of individual CWEs mapped to the

TABLE II
CVEs DISTRIBUTION BY MANUFACTURER

EV Chargers		EVs		Non-EVs		Other Traffic Devices	
Brand	CVEs	Brand	CVEs	Brand	CVEs	Brand	CVEs
Schneider Electric	26	Tesla	17	Mercedes	9	Roav	11
CirControl	9	Mercedes	7	Honda	4	NXP	10
Open Charge Point Protocol	5	BMW	7	Hyundai	3	Texas Instruments	4
GARO	4	Hyundai	4	Chevrolet	2	Blackvue	3
ABB	2	Renault	3	Kia	2	Microchip	3
StarCharge	2	Ford	2	Mazda	2	Cypress	2
HomePlug	1	Volkswagen	2	Audi	1	Econolite	2
		Honda	1	BMW	1	SWARCO	1
		NIO	1	Chrysler	1		
		Subaru	1	Nissan	1		
		Toyota	1	Suzuki	1		
				Toyota	1		

TABLE III
DISTRIBUTION OF VULNERABILITIES ACROSS PRIMARY CLASSES FOR EACH IoT CATEGORY

Primary CWE-888 Class	EV Chargers	EVs	Non-EVs	Other Traffic Devices	All
Access Control	1 (2%)		2 (8%)	6 (18%)	9 (6%)
API					
Authentication	16 (30%)	2 (5%)	3 (13%)	5 (15%)	26 (17%)
Channel	4 (7%)	3 (8%)	7 (29%)		14 (10%)
Cryptography	2 (4%)	3 (8%)		2 (6%)	7 (5%)
Entry Points					
Exception Management		2 (5%)		1 (3%)	3 (2%)
Failure to Release Memory					
Faulty Resource Release					
Information Leak	9 (17%)	2 (5%)	1 (4%)	3 (9%)	15 (10%)
Malware					
Memory Access		8 (21%)	1 (4%)	11 (33%)	20 (13%)
Memory Management					
Other	4 (7%)	7 (18%)	3 (13%)	2 (6%)	16 (11%)
Path Resolution	1 (2%)	1 (3%)			2 (1%)
Privilege		3 (8%)			3 (2%)
Predictability	5 (9%)		2 (8%)	2 (6%)	9 (6%)
Resource Management		1 (3%)	2 (8%)		3 (2%)
Risky Values		1 (3%)			1 (1%)
Synchronization		1 (3%)		1 (3%)	2 (1%)
Tainted Input	10 (19%)	4 (11%)	3 (13%)		17 (11%)
UI	2 (4%)				2 (1%)
Unused Entities					
Total of 6 Most Common	48 (89%)	28 (74%)	20 (83%)	29 (88%)	108 (72%)
Total	54	38	24	33	149

23 CWE-888 primary classes, for each of the IoT device categories and overall.

A. EV Charger vulnerabilities

Figure 2 shows the distribution of EV chargers' CWEs across CWE-888 primary classes. There were 49 CVEs that corresponded to 54 CWEs that affected EV charging stations or EV charger software. There were 27 unique CWEs among the 54 total, covering 10 of the 23 primary classes. The most common class was Authentication with 30% of the CWEs. The following top six classes made up 89% of all EV charger vulnerabilities: Authentication, Tainted Input, Information Leak, Predictability, Other, and Channel (see Table III).

B. EV vulnerabilities

Figure 3 shows the distribution of EVs' CWEs across CWE-888 primary classes. There were 46 CVEs that corresponded

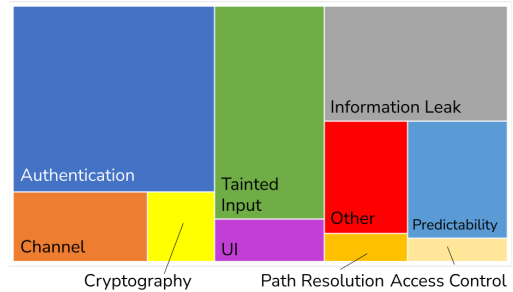


Fig. 2. Distribution of EV chargers' vulnerabilities across the primary classes to a total of 38 CWEs. This is due to the fact that 8 CVEs were NVD-CWE-noinfo, i.e., were missing a CWE number. There were 24 unique CWEs among the 38 total. The EV vulnerabilities belonged to 13 out of the 23 primary classes. 21% of the vulnerabilities belonged to the Memory Access

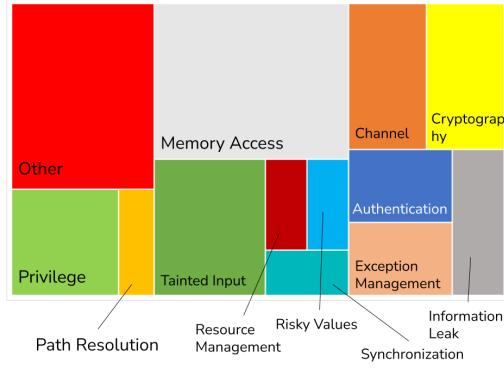


Fig. 3. Distribution of EVs' vulnerabilities across the primary classes

primary classes, which was the most common in this category. The top six primary classes accounted for 74% of the total vulnerabilities. They were Memory Access, Other, Tainted Input, Channel, Cryptography, and Privilege. The most common individual CWE was CWE-693 Protection Mechanism Failure, which is consistent with the results reported in [5]–[7]. In our dataset, all CWE-693 vulnerabilities were related to BMW's i Series and X Series EVs. CWE-693 refers to a product that either does not use or incorrectly uses a protection mechanism that is intended to defend against attacks [32]. One example of a protection mechanism failure is CVE-2018-9322 [33], where attackers could bypass the code-signing protection mechanism for firmware updates on BMWs to obtain a root shell.

C. Non-EV vulnerabilities

Figure 4 displays the distribution of Non-EVs' CWEs across the primary classes. There were a total of 28 CVEs with 24 total CWEs, among which there were 11 unique CWEs. Note that 5 CVEs were classified as NVD-CWE-noinfo. The Non-EV vulnerabilities covered 9 primary classes out of 23. The most dominant class was Channel with 29% of all vulnerabilities in this category. The top six primary classes accounted for 83% of the vulnerabilities for the Non-EVs. They were Channel, Authentication, Other, Tainted Input, Access Control, and Predictability. The most common individual CWE for Non-EVs was CWE-294 Authentication Bypass by Capture-replay. This vulnerability was not reported in [5]–[7], which is understandable having in mind that the CVEs with CWE-294 vulnerability were reported after the publication of [5]–[7]. CWE-294 describes a vulnerability that makes it possible for a malicious user to capture a signal used in the product and replay it to the receiver, resulting in the same or similar effect [34]. An example of this is CVE-2022-37305 [35], for which the remote keyless system of a Honda vehicle allowed attackers to unlock the car indefinitely after capturing five consecutive valid signals.

D. Other Traffic Devices vulnerabilities

Figure 5 shows the distribution of vulnerabilities that affected the Other Traffic Devices (i.e., automotive microcontrollers, traffic controllers and their software, and dash cameras) across the primary classes. There were 36 CVEs that corresponded to 33 total CWEs. Five CVEs were classified

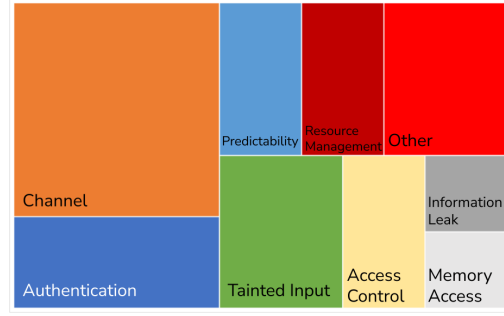


Fig. 4. Distribution of Non-EVs' vulnerabilities across the primary classes

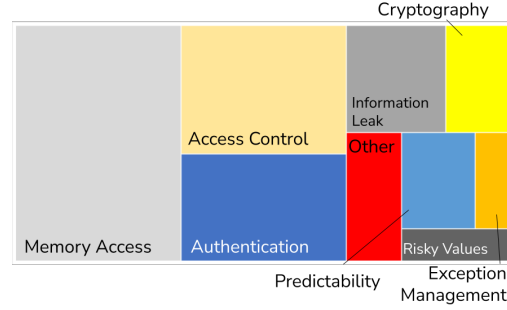


Fig. 5. Distribution of Other Traffic Devices' vulnerabilities across the primary classes

as NVD-CWE-noinfo. 22 unique CWEs were associated with the 33 total CVEs. These belonged to 9 out of the 23 total primary classes. The most common was Memory Access, which consisted of 33% of the vulnerabilities in this category. The 6 most common classes were Memory Access, Access Control, Authentication, Information Leak, Cryptography, and Other. In total, they accounted for 88% of all vulnerabilities in this category.

V. RQ2: ANALYSIS OF CVSS SCORES AND SEVERITY

In this section, we analyze the CVSS scores (shown in Figure 6) and CVSS severity levels (presented in Figure 7) for the four categories of transportation IoT devices). The CVSS score ranges from 0 to 10 and is a composite metric that integrates the exploitability metrics and impact metrics (i.e., the consequences of successful exploits), and combines them with the temporal and environmental factors [29].

As shown in Figure 6, the category with the highest median CVSS severity score was EV chargers, followed by Other Traffic Devices, EVs, and Non-EVs. We conducted a Kruskal-Wallis test on the four categories and obtained a p-value of 0.0007, rejecting the null hypothesis that there is no statistically significant difference among the CVSS scores. The results of the Dunn's post hoc test showed that the CVSS scores of EV chargers, EVs, and Other Traffic Devices categories were not different. However, all of them differed from the CVSS scores of the Non-EVs category based on the p-values of 0.00007, 0.0056, and 0.000955, respectively.

The mean CVSS severity score for the EV Chargers category was 7.87. The most common components that CVEs were associated with were the web interface, web server, and

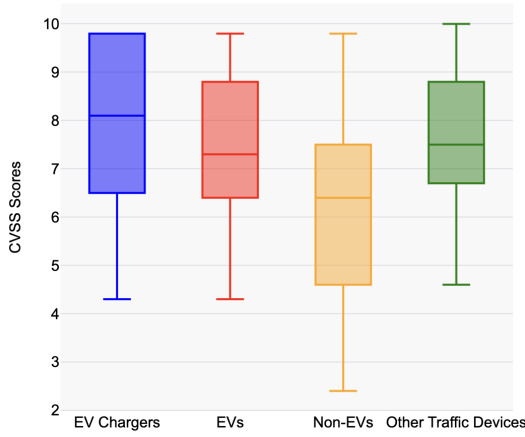


Fig. 6. Box plots of CVSS scores across the four categories

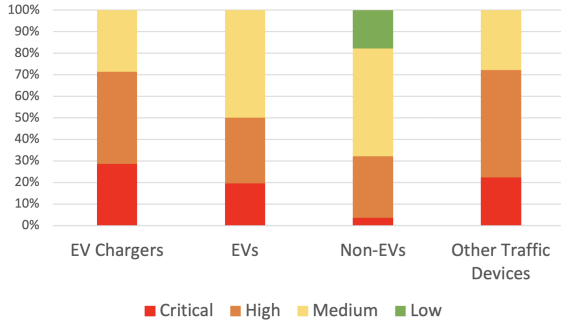


Fig. 7. CVSS severity classes across the four categories

communication protocol of the EV charger. The EVs category had a mean CVSS score of 7.32. The components with the most vulnerabilities were the infotainment system, Remote Keyless Entry (RKE) system, mobile apps used to control the car, and Telematics Control Unit (TCU). Note that the prior work [6] listed only the infotainment and TCU as the most vulnerable components. In addition to those, our results showed that mobile apps and RKE systems were among the most vulnerable components in the EVs and Non-EVs categories. The mean CVSS score of the Non-EVs category was 5.93. Similar to EVs, the most vulnerable components were the infotainment system, RKE, mobile app, and TCU. The Other Traffic Devices category had a mean CVSS score of 7.66. Among the multiple types of devices in this category, the most CVEs were associated with the automotive microcontrollers, followed by dash cameras.

Figure 7 shows the distribution of the CVEs among the four CVSS severity classes, for the four categories of transportation IoT devices. Furthermore, Table IV provides the numbers of critical and high severity vulnerabilities associated with each of the most vulnerable components, which are further discussed in Section VII.

VI. THREATS TO VALIDITY

Construct validity relates to the ability to measure what we intend to evaluate. As in other studies on security vulnerabilities, we searched for information on NIST’s NVD and MITRE’s CWE, which are widely used. Close exploration

of the Vulnerability Database VulDB [36] did not result in additional vulnerabilities for the devices considered in this paper. However, there are industry-specific databases such as VicOne [37] and Upstream [38] that may provide additional information on automotive vulnerabilities, which we plan to explore in our future work. Twenty two (out of 159) CVEs did not provide the corresponding CWE numbers. Two additional CVEs were in NVD-CWE-Other and therefore could not be classified as one of the existing CWEs. These 24 CVEs were excluded from the CWE analysis. In an attempt to extract comprehensive data, we searched for many manufacturers of EV chargers, EVs, Non-EVs, and other traffic devices, but for many of them, there were no CVEs reported. Even though we did a thorough search for manufacturers (see section III-A), it is possible that some less-known manufacturers were overlooked, which may have resulted in some sampling bias. On the other side, some companies such as Schneider Electric for EV chargers and Tesla for EVs had many CVEs reported for their products which skewed the results towards these companies.

Internal validity is based on factors that may affect the independent variables without the researchers’ knowledge. The quality of the extracted data depends on the quality and completeness of the information reported in NVD and CWE, and therefore consist an internal threat to validity. However, both NVD and CWE are widely used and trusted by researchers and practitioners alike. As with any other empirical study of vulnerabilities, it is not possible to account for undisclosed vulnerabilities and zero-day vulnerabilities.

Conclusion validity threats impact the ability to draw correct conclusions. The data sample size may affect the conclusion validity. The results presented in this paper are based on an analysis of 159 CVEs and the associated 149 CWEs, which constitute a fairly large sample. In spite of our effort to extract an exhaustive sample of vulnerabilities for transportation IoT devices, the analyses per IoT device category were based on smaller sample sizes (from 24 to 54 CWEs) which poses a threat to the conclusion validity.

External validity is focused on the generalizability. Our results only apply to the type of transportation IoT devices and vehicles covered in this paper. As can be seen in Table II, these IoT devices have been produced by different manufacturers, from different countries. The results, however, cannot be generalized to all IoT devices or other domains. Future empirical studies focused on additional transportation IoT devices and vehicles, as well as other domains can be conducted to further explore the generalizability of our findings.

VII. LESSONS LEARNED AND IMPLICATIONS

Our main findings about vulnerabilities reported for transportation IoT devices are as follows.

The considered transportation IoT devices had vulnerabilities reported in 16 out of the 23 primary classes. Out of these, the top 6 classes accounted for 72% of all vulnerabilities. The 6 most common primary classes for all of the IoT device categories together were Authentication, Channel,

TABLE IV
CRITICAL AND HIGH SEVERITY CVEs BY COMPONENT. (TOTAL NUMBER OF CVEs ARE GIVEN IN PARENTHESIS)

Severity	EV Chargers			EVs				Non-EVs				Other Traffic Devices	
	Web inter.	Web server	Comm. protocol	Infotainment	RKE	Mobile apps	TCU	Infotainment	RKE	Mobile apps	TCU	Micro-controllers	Other
Critical	4	7	1	4	0	0	2	0	0	1	0	1	7
High	4	7	6	10	1	0	1	1	0	3	0	9	9
Total	8 (12)	14 (21)	7 (9)	14 (21)	1 (7)	0 (4)	3 (4)	1 (6)	0 (6)	4 (6)	0 (5)	10 (19)	16 (17)

Information Leak, Memory Access, Other, and Tainted Input.

In each IoT device category, the 6 most common primary classes accounted for 74% to 89% of all reported vulnerabilities. For EV chargers, EVs, Non-EVs, and Other Traffic Devices, the top 6 classes contained 89%, 74%, 83%, and 88% of the vulnerabilities, respectively. This finding is consistent with the results presented in [3], which reported that security vulnerabilities in mission critical software were unevenly distributed, with the top 5 primary classes contributing from around 80% to 90% of vulnerabilities in each of the three datasets.

The most prominent vulnerability classes for EV Chargers were Authentication (30%), Information Leak (17%), and Tainted Input (19%). These indicate that EV chargers have problems with insecure passwords, insufficient authentication, encryption, data exposure or corruption, as well as possible injection attacks on their backend. Since EV chargers are typically accessible on the Internet [39] and have remote interfaces that support communication with the power grid, servers, and smartphones [14], the network attack vector is very prominent as indicated by our empirical results. Thus, most CWEs related to EV chargers were related to the front-end web interface (29.6%), the back-end web server (44.4%), and the communication protocol (11.1%).

The most common vulnerabilities for EVs were Memory Access (21%), Other (18%), and Tainted Input (11%). Half of the Memory Access vulnerabilities were CWE-787 Out-of-Bounds Write, showing that these types of vulnerabilities are still quite common. All 7 CWEs in the Other class were reported for BMW EVs and were attributed to CWE-693 Protection Mechanism Failure, which indicates a lack or incorrect use of protection mechanisms against attacks. Half of the Tainted Input CWEs were identified as CWE-20 Improper Input Validation. Note that EVs generally depend on software to function properly due to their Electronic Control Units (ECU), which manage engine safety, provide infotainment services [40], and regulate power supply, among other tasks. EVs are also often interconnected with ECUs of other vehicles and require Internet connections to keep the software updated and identify potential issues [41]. All 3 vulnerabilities that affected ECUs (i.e., CWE-77 Command Injection, CWE-20 Improper Input Validation, and CWE-74 Injection) belong to the Tainted Input class. In EVs, the majority of vulnerabilities were associated with the infotainment systems (47.3%), remote keyless entry (RKE) systems (13.1%), telematics control

units (TCU) system (13.1%), and mobile apps (5.3%).

The most common vulnerabilities for Non-EVs were Channel (29%), Authentication (13%), and Tainted Input (13%). Six of the 7 Channel vulnerabilities were due to the RKE systems that allowed for replay attacks to unlock the vehicle by using the same signal every time. Two of the 3 Authentication CWEs were CWE-287 Improper Authentication indicating that the user's identity was not proven sufficiently before giving access. All 3 Tainted Input vulnerabilities were CWE-134 Use of Externally-Controlled Format String and were due to mishandling of format-string specifiers in device names for the vehicles' Bluetooth stacks. Interestingly, Non-EVs had the same vulnerable systems as EVs. Thus, the vulnerabilities were mostly associated with the infotainment system (20.8%), RKE (25%), mobile apps (29.2%) and TCU (12.5%). Although many Non-EVs are connected to the Internet, they seem to be less exposed to network attacks than EVs.

The most common vulnerabilities for Other Traffic Devices were Memory Access (33%), Access Control (18%), and Authentication (15%). Out of 11 Memory Access vulnerabilities, four were CWE-787 Out-of-bounds Write and one was CWE-125 Out-of-bounds Read, while others were related to buffer overflows (i.e., CWE-119 Improper Restriction of Operations within the Bounds of a Memory Buffer, CWE-120 Classic Buffer Overflow, and CWE-121 Stack-based Buffer Overflow). Of the 6 Access Control vulnerabilities, two were CWE-732 Incorrect Permission Assignment for Critical Resource and two were CWE-284 Improper Access Control. The Authentication vulnerabilities were all different and included CWE-307 Improper Restriction of Excessive Authentication Attempts, CWE-306 Missing Authentication for a Critical Function, and CWE-287 Improper Authentication, showing that weak or lack of authentication is a major problem. The vulnerable components included: dash cameras (45.4%), microcontrollers (42.4%), Econolite traffic control software (9.1%), and SWARCO traffic controller (3%). Most of the vulnerabilities in this category had network attack vectors because these devices are often accessed through the Internet or cellular networks. For example, many dash cameras have cellular connectivity for remote access to the footage.

There were similarities but also differences among the top six dominant vulnerability classes for different IoT devices categories. Other was the only vulnerability class that was among the top six classes for all four IoT device categories.

Authentication, Channel, and Tainted Input were among the top six vulnerability classes for three IoT devices categories. Access Control, Cryptography, Information Leak, Memory Access, and Predictability were among top six vulnerability classes for two IoT devices categories, while Privilege was among the top six vulnerability classes only for one IoT devices category.

The most common vulnerabilities for transportation IoT devices identified in this paper are among MITRE’s top 25 most dangerous CWEs [42]. For example, for EV chargers, we identified 4 instances of CWE-79 Cross-Site Scripting, 3 instances of CWE-352 Cross-Site Request Forgery, 4 instances of CWE-287 Improper Authentication, 4 instances of CWE-798 Use of Hard-coded credentials, and 3 instances of CWE-306 Missing Authentication for Critical Function, which are ranked 2nd, 9th, 13th, 18th, and 20th, respectively, on the top 25 most dangerous CWEs list. The dominant vulnerabilities for the other three categories of IoT devices were also among the top 25 most dangerous CWEs, but are not discussed here due to space limitations.

Many dominant vulnerability classes identified in this paper are also among the OWASP Top 10 Vulnerabilities [43]. For example, the Authentication class is similar to OWASP’s Identification and Authentication Failures category, Access Control corresponds to OWASP’s Broken Access control, and Tainted Input includes the OWASP’s Injection category.

Our main findings related to CVSS scores and severity are as follows.

EV chargers category had the highest mean and median CVSS scores and the most critical severity among the four categories. For EV chargers, 94% of the vulnerabilities had a network attack vector, which means they can be exploited remotely, without physical access. The severity is likely high because when attacking an EV charging station with an Internet connection, attackers can gain unauthorized access beyond the charger, potentially allowing them to target critical components of the power grid or transportation network [44].

EVs and Other Traffic Devices had comparable mean and median CVSS scores. Note that Other Traffic Devices had a higher percentage of vulnerabilities with network attack vectors than EVs (i.e., 61% vs. 30%).

Non-EVs had the lowest mean and median CVSS scores, which were statistically significantly different from the CVSS scores of the other three categories. This may be due to the fact that Non-EVs had the lowest proportion of CVEs that were exploitable through the network (i.e., 21%), indicating that physical or adjacent attack vectors were more commonly used in the case of regular cars. However, note that there were fewer CVE reports for this category.

Our findings have the following actionable implications that could be useful for developers, manufacturers, and researchers.

Focusing on several dominant CWE classes is an efficient way to improve the security of transportation IoT devices.

For example, this could be achieved by secure software development focused on avoiding these types of vulnerabilities and/or composing a code review checklist that could be used in the software verification process.

Specifically address persistent types of vulnerabilities such as missing or improper authentication, improper input validation, command injection, information leak, and memory access including buffer overflow, which continue to prevail despite the advances in cybersecurity.

Development and deployment of EV chargers must account for cybersecurity because they pose a significant risk not only to themselves and EVs but also to the power grid. EV chargers had the highest number of reported CVEs and these CVEs had the highest mean and median CVSS scores.

Many transportation IoT devices (i.e., EV chargers, EVs and Other Traffic Devices) are typically accessible through the Internet and also have many vulnerabilities that can be exploited remotely, introducing broader attack vectors and high risk that, to be addressed, would require more rigorous design and implementation efforts.

Most vulnerabilities associated with transportation IoT devices empirically identified in this study are among MITRE’s top 25 most dangerous CWEs and OWASP top 10 vulnerabilities which proves the existence of high risk and further reinforces the need for addressing the IoT devices security proactively.

VIII. CONCLUSIONS

This paper is focused on empirical analysis of security vulnerabilities. Specifically, we identified the dominant vulnerability classes in four IoT device categories: EV chargers, EVs, Non-EVs, and Other Traffic Devices. Our results showed that the distribution of the vulnerabilities is skewed, with the top six classes accounting for 74% to 89% of all vulnerabilities in each IoT device category. Furthermore, although the EV chargers had the highest CVSS scores, they were not statistically significantly different than the CVSS scores of EVs and Other Traffic Devices. The Non-EVs had the lowest CVSS scores, which were statistically significantly different than the other categories of transportation IoT devices. In addition to compiling the lessons learned, we identified the implications of our findings and provided insights that can be used by researchers, developers, and manufacturers to cost-efficiently improve the security of transportation IoT devices.

Our future research includes (i) data triangulation (i.e., utilizing industry-specific databases as additional sources of information), and (ii) exploring attackers’ behaviors that can lead to exploitation of identified vulnerabilities.

DATA AVAILABILITY

The dataset “Transportation-IoT-Vulnerabilities-DSN2025” used in this paper is licensed under CC BY-SA 4.0. The dataset’s DOI is 10.5281/zenodo.15115541 and it is available at <https://zenodo.org/records/15115541>. Anyone using this dataset must include the attribution to this paper.

REFERENCES

- [1] IBM, "X-Force Threat Intelligence Index 2024," 2024, accessed: 2025-02-24. [Online]. Available: <https://www.ibm.com/downloads/cas/JZ7GZ6XR>
- [2] NIST, "National Vulnerability Database (NVD)," <https://nvd.nist.gov/>, 2025, accessed: 2025-02-24.
- [3] K. Goseva-Popstojanova and J. Tyo, "Experience report: Security vulnerability profiles of mission critical software: Empirical analysis of security related bug reports," in *IEEE 28th International Symposium on Software Reliability Engineering (ISSRE)*, 2017, pp. 152–163.
- [4] Common Weakness Enumeration, "CWE-888: Software Fault Pattern (SFP) Clusters," 2023, accessed: 2025-02-24. [Online]. Available: <https://cwe.mitre.org/data/definitions/888.html>
- [5] W. Xiong, M. Gülsever, K. M. Kaya, and R. Lagerström, "A study of security vulnerabilities and software weaknesses in vehicles," in *Secure IT Systems: 24th Nordic Conference, NordSec 2019*. Springer, 2019, pp. 204–218.
- [6] K. M. Kaya, "A study of vulnerabilities and weaknesses in connected cars," KTH Royal Institute of Technology, Tech. Rep., June 30 2019. [Online]. Available: <https://www.diva-portal.org/smash/get/diva2:1356203/FULLTEXT01.pdf>
- [7] M. Gulsever, "A study on vulnerabilities in connected cars," KTH Royal Institute of Technology, Tech. Rep., June 7 2019. [Online]. Available: <https://www.diva-portal.org/smash/get/diva2:1351157/FULLTEXT01.pdf>
- [8] P. Bhattacharya, L. Ulanova, I. Neamtii, and S. C. Koduru, "An empirical analysis of bug reports and bug fixing in open source Android apps," in *2013 17th European Conference on Software Maintenance and Reengineering*. IEEE, 2013, pp. 133–143.
- [9] M. Jimenez, M. Papadakis, T. F. Bissyande, and J. Klein, "Profiling Android vulnerabilities," in *IEEE International Conference on Software Quality, Reliability and Security (QRS)*, 2016, pp. 222–229.
- [10] A. Gorbenko, A. Romanovsky, O. Tarasyuk, and O. Biloborodov, "Experience report: Study of vulnerabilities of enterprise operating systems," in *28th IEEE International Symposium on Software Reliability Engineering (ISSRE)*, 2017, pp. 205–215.
- [11] M. Vålja, M. Korman, and R. Lagerström, "A study on software vulnerabilities and weaknesses of embedded systems in power networks," in *2nd Workshop on Cyber-Physical Security and Resilience in Smart Grids*, 2017, p. 47–52.
- [12] N. S. Harzevili, J. Shin, J. Wang, S. Wang, and N. Nagappan, "Characterizing and understanding software security vulnerabilities in machine learning libraries," in *2023 IEEE/ACM 20th International Conference on Mining Software Repositories (MSR)*. IEEE, 2023, pp. 27–38.
- [13] M. Alfadel, D. E. Costa, and E. Shihab, "Empirical analysis of security vulnerabilities in Python packages," *Empirical Software Engineering*, vol. 28, no. 3, p. 59, 2023.
- [14] S. Acharya, Y. Dvorkin, H. Pandžić, and R. Karri, "Cybersecurity of smart electric vehicle charging: A power grid perspective," *IEEE Access*, vol. 8, pp. 214 434–214 453, 2020.
- [15] D. Ronanki and H. Karneddi, "Electric vehicle charging infrastructure: Review, cyber security considerations, potential impacts, countermeasures, and future trends," *IEEE Journal of Emerging and Selected Topics in Power Electronics*, vol. 12, no. 1, pp. 242–256, 2024.
- [16] N. Bhusal, M. Gautam, and M. Benidris, "Cybersecurity of electric vehicle smart charging management systems," in *2020 52nd North American Power Symposium (NAPS)*, 2021, pp. 1–6.
- [17] Z. Pourmirza and S. Walker, "Electric vehicle charging station: Cyber security challenges and perspective," in *2021 IEEE 9th International Conference on Smart Energy Grid Engineering (SEGE)*, 2021, pp. 111–116.
- [18] T. Nasr, S. Torabi, E. Bou-Harb, C. Fachkha, and C. Assi, "Power jacking your station: In-depth security analysis of electric vehicle charging station management systems," *Computers Security*, vol. 112, p. 102511, 2022.
- [19] Z. Muhammad, Z. Anwar, and B. Saleem, "A cybersecurity risk assessment of electric vehicle mobile applications: Findings and recommendations," in *2023 3rd International Conference on Artificial Intelligence (ICAI)*, 2023, pp. 45–51.
- [20] S. Shirvani, Y. Baseri, and A. Ghorbani, "Evaluation framework for electric vehicle security risk assessment," *IEEE Transactions on Intelligent Transportation Systems*, vol. 25, no. 1, pp. 33–56, 2024.
- [21] J. Johnson, B. Anderson, B. Wright, J. Quiroz, T. Berg, R. Graves, J. Daley, K. Phan, M. Kunz, R. Pratt, T. Carroll, L. R. O'Neil, B. Dindlebeck, P. Maloney, J. O'Brien, D. Gotthold, R. Varriale, T. Bohn, and K. Hardy, "Cybersecurity for electric vehicle charging infrastructure," 2022, accessed: 2025-02-24. [Online]. Available: <https://www.osti.gov/biblio/1877784>
- [22] Y. Feng, S. E. Huang, W. Wong, Q. A. Chen, Z. M. Mao, and H. X. Liu, "On the cybersecurity of traffic signal control system with connected vehicles," *IEEE Transactions on Intelligent Transportation Systems*, vol. 23, no. 9, pp. 16 267–16 279, 2022.
- [23] P. Sharma and J. Gillanders, "Cybersecurity and forensics in connected autonomous vehicles: A review of the state-of-the-art," *IEEE Access*, vol. 10, pp. 108 979–108 996, 2022.
- [24] Electric Drive Transportation Association, "Charging Equipment Showroom," 2023, accessed: 2025-02-24. [Online]. Available: <https://www.golectricdrive.org/charging-ev/charging-equipment-showroom>
- [25] Internal Revenue Service, "Manufacturers and models for new qualified clean vehicles purchased in 2022 and before," 2023, accessed: 2025-02-24. [Online]. Available: <https://www.irs.gov/credits-deductions/manufacturers-and-models-for-new-qualified-clean-vehicles-purchased-in-2022-and-before>
- [26] H. Wen, Q. A. Chen, and Z. Lin, "Plug-N-Pwned: Comprehensive vulnerability analysis of OBD-II dongles as a new Over-the-Air attack surface in automotive IoT," in *29th USENIX Security Symposium*, 2020, pp. 949–965.
- [27] U.S. News and World Report, "All the Car Brands Available in America," 2023, accessed: 2025-02-24. [Online]. Available: <https://cars.usnews.com/cars-trucks/advice/car-brands-available-in-america>
- [28] National Vulnerability Database (NVD), "NVD CWE Slice," <https://nvd.nist.gov/vuln/categories>, 2023, accessed: 2025-02-24.
- [29] Common Vulnerability Scoring System (CVSS), "Specification Document," Online: <https://www.first.org/cvss/v4.0/specification-document>, 2023, accessed: 2025-02-24.
- [30] Common Weakness Enumeration, "CWE," 2024, accessed: 2025-02-24. [Online]. Available: <https://cwe.mitre.org/data/index.html>
- [31] —, "CWE-699: Software Development," Online: <https://cwe.mitre.org/data/definitions/699.html>, 2023, accessed: 2025-02-24.
- [32] —, "CWE-693: Protection Mechanism Failure," 2023, accessed: 2025-02-24. [Online]. Available: <https://cwe.mitre.org/data/definitions/693.html>
- [33] National Vulnerability Database, "CVE-2018-9322 Detail," 2018, accessed: 2025-02-24. [Online]. Available: <https://nvd.nist.gov/vuln/detail/cve-2018-9322>
- [34] Common Weakness Enumeration, "CWE-294: Authentication Bypass by Capture-replay," 2023, accessed: 2025-02-24. [Online]. Available: <https://cwe.mitre.org/data/definitions/294.html>
- [35] National Vulnerability Database, "CVE-2022-37305 Detail," 2022, accessed: 2025-02-24. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2022-37305>
- [36] VulDB, "Vulnerability Database and Vulnerability Intelligence," <https://vuldb.com/>, 2024, accessed: 2025-02-24.
- [37] VicOne, "Automotive Zero-Day Vulnerabilities," <https://vicone.com/automotive-zero-day-vulnerabilities>, 2024, accessed: 2025-02-24.
- [38] Upstream, "Upstream AutoThreat@ Intelligence Cyber Incident Repository," <https://upstream.auto/research/automotive-cybersecurity/?id=null>, 2024, accessed: 2025-02-24.
- [39] J. Johnson, T. Berg, B. Anderson, and B. Wright, "Review of electric vehicle charger cybersecurity vulnerabilities, potential impacts, and defenses," *Energies*, vol. 15, no. 11, 2022. [Online]. Available: <https://www.mdpi.com/1996-1073/15/11/3931>
- [40] C. Bernardini, M. R. Asghar, and B. Crispo, "Security and privacy in vehicular communications: Challenges and opportunities," *Vehicular Communications*, vol. 10, pp. 13–28, 2017. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S2214209617300803>
- [41] S. Prasad, "Connected vehicle ecosystem – Why do electric vehicles need connectivity?" *EVreporter*, 2022. [Online]. Available: <https://evreporter.com/connected-vehicle-ecosystem-why-do-e-vehicles-need-connectivity/>

- [42] MITRE, “2023 CWE Top 25 Most Dangerous Software Weaknesses,” https://cwe.mitre.org/top25/archive/2023/2023_top25_list.html#top25list, 2023, accessed: 2025-02-24.
- [43] Common Weakness Enumeration, “Weaknesses in OWASP Top Ten (2021),” 2021, accessed: 2025-02-24. [Online]. Available: <https://cwe.mitre.org/data/definitions/1344.html>
- [44] S. Hamdare, O. Kaiwartya, M. Aljaidi, M. Jugran, Y. Cao, S. Kumar, M. Mahmud, D. Brown, and J. Lloret, “Cybersecurity risk analysis of electric vehicles charging stations,” *Sensors*, vol. 23, p. 6716, July 2023.